Computers & Security 154 (2025) 104450

Contents lists available at ScienceDirect

Computers & Security

journal homepage: www.elsevier.com/locate/cose

Full length article

Contrasting the optimal resource allocation to cybersecurity controls and cyber insurance using prospect theory versus expected utility theory

Chaitanya Joshi [a,d,*], Sergeja Slapničar [b,c], Jinming Yang [a], Ryan K.L. Ko [b]

[a] Department of Statistics, University of Auckland, Auckland, New Zealand
[b] UQ Cyber, University of Queensland, Brisbane, Australia
[c] UQ Business School, University of Queensland, Brisbane, Australia
[d] New Zealand Institute for Security and Crime Science, Hamilton, New Zealand

ARTICLE INFO

MSC:
0000
1111

Keywords:
Cybersecurity
Cyber insurance
Prospect theory
Expected utility theory
Resource allocation

ABSTRACT

Protecting against cyber-threats is essential for every organization and can be achieved by investing in cybersecurity controls and purchasing cyber insurance. These two alternatives are interlinked, as insurance premiums can be reduced by investing more in cybersecurity controls. However, cyber insurance remains under-utilized, a puzzle that Expected Utility Theory (EUT) cannot explain. In this paper, we analyze how decision-makers allocate resources between cybersecurity controls and cyber insurance, comparing optimal allocation under Prospect Theory (PT) to that under EUT. We propose a new functional form of risk curves to model the relationship between investment in cybersecurity controls and cyber risk, demonstrating how a bespoke risk curve can be fitted for an organization. We derive the optimal allocation strategy of resources to cybersecurity controls and cyber insurance under EUT and PT paradigms. Using mathematical results and numerical examples, we identify specific behavioral considerations in PT that lead to different resource allocations compared to EUT. We show that decision-makers aligned with EUT are generally indifferent to purchasing insurance, whereas those aligned with PT favor full insurance coverage; otherwise, they invest more in self-protection. Our results indicate that, in addition to a challenging cybersecurity environment and the nature of insurance coverage, behavioral aspects (diminished sensitivity to losses and probability weights) play a key role in determining the optimal level of investment in cybersecurity.

1. Introduction

In the past decade, cyber risk has consistently ranked among the top five business risks, and its significance is only expected to grow (WEF, 2024, World Economic Forum). Effective management of this risk is crucial for every organization. There are two primary approaches to mitigate cyber risk: (i) investing in self-protecting cybersecurity measures (controls) to minimize the likelihood of a cyber incident and (ii) transferring the risk through cyber insurance. Both approaches demand substantial resources, making it essential to optimize the allocation of resources between cybersecurity controls and cyber insurance (Gordon et al., 2003). This optimization is particularly challenging due to two key factors.

First, investments in cybersecurity controls and cyber insurance are related (Shetty et al., 2018). At a certain level, relying only on cybersecurity controls to reduce risk becomes prohibitively expensive (Marotta et al., 2017), and it is cost-effective to transfer the residual risk to a third party by insuring it. Insurance premiums can be reduced if an organization reduces the insured risk by improving its cybersecurity protection (Marotta et al., 2017; Uuganbayar et al., 2021; Mott et al., 2023). Due to interrelated losses and the contagion effects of a cyber incident within and between industries, investing in cybersecurity controls improves social welfare by improving the overall level of cybersecurity of organizations and, ultimately, consumers (Öğüt et al., 2011; Mukhopadhyay et al., 2013; Biener et al., 2015; Marotta et al., 2017). Second, cyber threats are constantly evolving, and new modalities of attacking organizations are being developed, which introduces great uncertainty in cybersecurity decisions (Hubbard and Seiersen, 2023). As a result, neither the level of protection cybersecurity controls will provide nor the level of coverage of an insurance can be accurately assessed (Boehm et al., 2019).

Despite the increasing prevalence of cyber risks, cyber insurance remains under-utilized, with demand falling significantly short of expectations given the severity of cyber risks (Miller, 2019; Sullivan and Nurse, 2021; Mott et al., 2023). The main reasons for this is that cyber insurance has several unique challenges, which we describe below.

* Corresponding author at: Department of Statistics, University of Auckland, Auckland, New Zealand.
E-mail address: chaitanya.joshi@auckland.ac.nz (C. Joshi).

https://doi.org/10.1016/j.cose.2025.104450
Received 28 November 2024; Received in revised form 17 February 2025; Accepted 17 March 2025
Available online 25 March 2025
0167-4048/© 2025 The Authors. Published by Elsevier Ltd. This is an open access article under the CC BY-NC-ND license (http://creativecommons.org/licenses/by-nc-nd/4.0/).

Insurers face significant difficulties in insuring cyber risks due to the lack of statistical data on incidents, high uncertainty, information asymmetry, the lack of auditing procedures to verify controls of the insured companies (Mott et al., 2023), and a small market base to pool risks (Yurcik and Doss, 2002; Eling and Schnell, 2016; Marotta et al., 2017). These factors increase insurers' business risk (Eling and Schnell, 2016; Shetty et al., 2018), lead to difficult-to-estimate pricing of insurance (Mott et al., 2023) and higher premium costs (Mukhopadhyay et al., 2013; Biener et al., 2015). Due to high risks that insurers face, policies have unclear coverage, exclusions and limited coverage (Arce et al., 2024; Cremer et al., 2024a; Wrede et al., 2020) or low indemnity limits (Ferland, 2019); in short, indemnities tend to be lower than the loss (Romanosky, 2016; Marotta et al., 2017; Uuganbayar et al., 2021).

For organizations considering cyber insurance, the diverse consequences of a cyber incident — ranging from financial and operational to managerial, health-related, and reputational — and the interrelated losses make it hard to estimate the potential impact of a cyber incident (Öğüt et al., 2011; Sullivan and Nurse, 2021). Organizations themselves are struggling to quantify their cyber risk financially and tend to assess it qualitatively (Freund and Jones, 2014; Hubbard and Seiersen, 2023; Pollmeier et al., 2023). Companies often do not understand well what claims their insurance policy includes (Romanosky, 2016).

At times, organizations are unable to even prove the loss to the insurance company to get the indemnity (Öğüt et al., 2011). A case in point is the 2017 court battle between Merck and its insurer over the NotPetya malware attack, which caused the destruction of data on 40,000 computers and resulted in losses of USD 1.4 billion. The insurer initially denied Merck's claim, citing a "war exclusion" clause. However, they eventually settled for USD 700 million (Adler, 2024). In the current geo-political environment, it is also noteworthy that most insurance policies include war exclusion clauses (Ferland, 2019; Woods and Weinkle, 2020; Cremer et al., 2024b). Moreover, mandated cybersecurity controls by insurers and better insights into prospective insureds have led some organizations to struggle with obtaining insurance and transferring their risk (Mott et al., 2023).

Eling and Wirfs (2019) distinguish between "cyber risks of daily life", which are insurable, and "extreme cyber risks", which are not insurable because of diversification properties and changes that render past data less useful. Unlike other severe operational risks (such as natural disasters), self-protection against cyber risk is not only crucial but also a viable alternative to insurance. Organizations may even prioritize self-protection as their primary strategy for managing cyber risk.

All these challenges might contribute to under-insurance of cyber risks. Crucially, they also highlight the need to model the relationship between investment in cybersecurity controls and the corresponding cyber risk. Yet, except for (Gordon and Loeb, 2002), we could not find any other attempts to explicitly model this relationship.

As we detail in Section 2.3, there are a few studies that discuss optimal resource allocation to cyber security controls and cyber insurance. All of them, however, assume that the decision-makers make choices that align with the expected utility theory (EUT). While EUT is seen as a benchmark for rational decision-making, extensive behavioral research documents that prospect theory (PT) (Kahneman and Tversky, 1979; Tversky and Kahneman, 1992) can describe the risky choices of the large majority of individuals more accurately (Pitthan and De Witte, 2021; Barberis, 2013).

PT accounts for the differing perceptions of gains and losses, emphasizing that losses often weigh more heavily on decision-makers than equivalent gains. This theory explains that managers exhibit loss aversion, focusing on the magnitude of potential losses, which influences their risk management strategies (Bell, 1985; March and Shapira, 1987; Lyytinen et al., 1998). PT also highlights that the value of losses and gains is subjective, as perceived by decision-makers. The diverse consequences of cyber risk imply that resource allocation decisions will depend not only on the face value of monetary gains or losses but also on their subjective value. Skeoch (2022) argues that using PT for resource allocation could be more appropriate. However, no published work on cybersecurity to date has analyzed the optimal investment allocation derived from PT. Part of the problem is the application of PT in real-world contexts (Barberis, 2013), which is somewhat ambiguous.

The objective of this study is to contrast the optimal allocation of resources to cybersecurity controls and cyber insurance under PT with that under EUT. However, this allocation cannot be derived without explicitly modeling the relationship between the investment in cybersecurity controls and the corresponding cyber risk. We propose a flexible and easily interpretable modeling framework to model this risk curve. We derive mathematical expressions for the decision-makers' value function under the PT paradigm and the utility function under the EUT paradigm. We consider the following three cases: (i) full insurance, (ii) under-insurance in which only 80% of the loss from a cyber-attack is covered, and (iii) no insurance, and derive the optimal allocation of resources to cybersecurity controls and cyber insurance (for the first two cases) under both EUT and PT.

The rest of this paper is organized as follows. Section 2 provides the background on EUT and PT as well as literature review of relevant research. In Section 3, we describe the assumptions and derive the mathematical expressions for EUT and PT. A new way to model the risk curve and how a bespoke risk curve could be estimated for a given organization is discussed in Section 4, followed by numerical examples in Section 5. Finally, we conclude by discussing the important implications as well as limitations of our results in Section 6.

2. Background

2.1. Expected utility theory

EUT is a normative account of how individuals (should) make risk choices given their utility function and the initial wealth (Von Neumann and Morgenstern, 1947). It has long been widely accepted as a standard of rationality (Back, 2017). EUT implies that a decision-maker will choose the decision that will maximize the expected value of the utility function. Let χ be the set of all possible outcomes x, $u(x)$ be the value of the utility function for the outcome x and $p(x)$ be the probability of outcome x. The expected utility is given by

$$E[u(x)] = \sum_{x \in \chi} u(x)p(x). \tag{1}$$

EUT assumes that individuals derive utility from the net wealth, which considers both their initial wealth and the outcomes of their choices. If an individual has initial wealth W, and they face a risky decision that could result in additional gains or losses $\pm x$, the resulting net wealth will be $W \pm x$. By explicitly accounting for W, expected utility theory explains that both the magnitude of potential outcomes and their interaction with initial wealth influence decisions.

While EUT represents how a rational person would evaluate the outcomes, it is possible to model certain risk preferences by using an appropriately formulated utility function. For instance, risk aversion can be modeled in a number of different ways (Back, 2017). One of the most commonly used risk aversion formulation (Banks et al., 2015; Back, 2017; Ejaz et al., 2021a) is the constant relative risk aversion (CRRA) which is of the form

$$u(x) = (W - x)^r, \tag{2}$$

where x represent the cost (loss) associated with a particular choice/action, and $1 - r$ is the coefficient of CRRA which measures the proportion of wealth an individual will choose to hold on a risky asset (Ejaz et al., 2021b).

The coefficient r can be used to model a multitude of risk behaviors. $r > 1$ represents a risk-seeking (gambling) behavior, $r = 1$, represents

risk-neutral and $0 < r < 1$ represents a risk-averse behavior. A risk-averse individual will prefer the certainty of small losses (insurance premiums) over the (small) possibility of a much larger loss. However, often people do not make decisions that are consistent with the EUT (Kahneman and Tversky, 1979; Tversky and Kahneman, 1992; Etner et al., 2012; Gilboa and Marinacci, 2013). For instance, EUT cannot explain the low uptake of some low probability-high consequences insurance products (de Smidt and Botzen, 2018; Hwang, 2021).

2.2. Prospect theory

In their two seminal studies about PT (Kahneman and Tversky, 1979; Tversky and Kahneman, 1992), Kahneman and Tversky (henceforth KT) proposed a theory that more accurately describes individuals' behavior in risky decision-making.[1] PT has four distinct characteristics (KT): (i) People make decisions between risky options not based on the impact on their wealth but rather in relation to a reference point that leads them to see some outcomes as gains and others as losses (*reference dependence*). (ii) They feel the pain of losses more intensely than the pleasure of an equivalent gain, resulting in loss aversion (*loss aversion*). (iii) The sensitivity to differences in outcomes diminishes with increasing amounts (*diminishing sensitivity*), which renders the value function concave for gains and convex for losses. (iv) Individuals weight probabilities of gains and losses differently and tend to overweight low and underweight high probabilities (*probability weighting*).

PT is similar to EUT in that both explain an *individual's* decision-making under risk. However, while EUT considers the utility — normally expressed in terms of monetary gains/losses — PT instead considers the value of those gains/losses as perceived by the decision-maker. As a consequence, while EUT assumes that individuals evaluate outcomes based on their levels of wealth, PT suggests that individuals evaluate outcomes based on the change in the value of their wealth compared to their reference point. Skeoch (2022) hypothesize that this could prove important in modeling the optimal allocation of resources between cyber insurance and cybersecurity controls, where the loss function is still primarily monetary but has an additional dimension in the form of loss of information.

According to EUT, a decision-maker perfectly and rationally processes information to maximize expected utility, and accurately assesses probabilities and outcomes of risky decisions. However, prior research indicates that individuals often struggle to predict and quantify the risks associated with extreme, uncertain, and rare events, such as a catastrophic cyber-attack (e.g., Taleb, 2007; Power, 2009; Komljenovic et al., 2016; Kay and King, 2020). In contrast to measurable risks, which benefit from extensive historical data and reliable future predictability (which facilitates the reliance on EUT), a successful cyber-attack is a unique event. The probability assigned to such an event is considered 'subjective' or 'personal' rather than objective (Kay and King, 2020). Cyber risk management often relies on Likert scales and heat maps based on qualitative and subjective evaluations of cyber risk likelihood and impact (Böhm et al., 2018; Pollmeier et al., 2023; Slapničar et al., 2023b).

Several biases described in the literature call into question the rational behavior of managers when making risky decisions: wishful thinking (Rhee et al., 2012), optimistic bias (Cho et al., 2010; Oltramari and Kott, 2018), perceived controllability bias (Rhee et al., 2012), overconfidence, or a biased assessment of own skills and talent (Kahneman and Lovallo, 1993), which can cause individuals to interpret uncertain situations in a self-serving manner (Julisch, 2013) and leads to less preventive behavior in cyber risk management (Jalali et al., 2019).

Prior research also documents other behaviors related to decision-making under risk, which PT can describe better than EUT: probabilities are not the primary concern of managers who associate risk with the magnitude of loss (Bell, 1985). Most risk management approaches concentrate on adverse outcomes and how to avoid them (Lyytinen et al., 1998), demonstrating loss aversion. This phenomenon translates to the use of terms such as "maximum exposure" or "worst or best case" (March and Shapira, 1987) in practice. This evidence underscores the importance of studying PT and other behavioral theories in the context of cyber security risk management.

From a mathematical perspective, PT is distinct from EUT in how it defines the value function and the probability weights. For the relative (reference dependent) gain/loss x, the *value function* in PT is defined as

$$v(x) = \begin{cases} x^{\alpha}, & \text{if } x \geq 0, \\ -\lambda|x|^{\alpha}, & \text{if } x < 0, \end{cases} \tag{3}$$

where parameter α controls the curvature of the value function and λ represents the level of loss aversion. The diminishing sensitivity assumption requires to make the value function concave in the gain domain and convex in the loss domain, this is achieved by restricting the value of α to be between 0 and 1. If the parameter $\lambda = 1$, it represents a loss-neutral behavior, whereas, $\lambda > 1$ represents loss aversion by giving a higher weight to losses. The probability weighting function is defined as

$$w(p) = \frac{p^{\beta}}{(p^{\beta} + (1-p)^{\beta})^{1/\beta}}, \tag{4}$$

where p is the probability and $\beta > 0$ is the parameter. When $\beta = 1$, decision weights are linear, just like in EUT, where $w(p) = p$. For $\beta < 1$, the weight function will be an inverse-S shaped function which will overweight low probabilities and underweight high probabilities. Empirical studies have shown that, $0.5 \leq \alpha \leq 1$, $1 \leq \lambda \leq 2.5$ and $0.5 \leq \beta \leq 1$ (Gonzalez and Wu, 1999; Schmidt et al., 2008; Bruhin et al., 2010). The median of α, λ and β are 0.88, 2.25 and 0.65 according to Tversky and Kahneman (1992).

These characteristics of PT lead to four patterns of risk choices. While on one hand, individuals tend to be risk averse for gains and risk seeking for losses of high probability, on the other hand, they are risk-seeking for gains and risk averse to losses of low probability (Tversky and Kahneman, 1992). The latter is of much relevance to cyber insurance. Individuals are more motivated to avoid further losses than to achieve gains, even if these choices are more risky. This explains why people would prefer a certain small loss to a very small chance of incurring a much larger loss (i.e., why they buy insurance).

According to PT, the decision-maker will choose the option that maximizes the overall value V given by

$$V(x) = \sum_{x \in \chi} v(x) w(p(x)). \tag{5}$$

Although PT is currently one of the most prominent descriptive theories of decision-making under risk, a rather limited number of studies apply it to insurance demand (Sydnor, 2010; Barseghyan et al., 2013; Schmidt, 2016; Hwang, 2021). These studies have considered home, health, long-term care, disability or auto insurances. One of the challenges in applying PT is that it is far from straightforward what a reference point is in different contexts and decisions. A reference point has significant implications for the relationship between loss aversion and the up-take of insurance (Hwang, 2021): it determines whether the outcome of a decision is perceived as a gain or a loss and how each of them is weighted.

In the original PT, the reference point is the status quo. Previous research has adopted various solutions: Sydnor (2010) and Hwang (2021) interpreted the status quo by considering initial wealth before the insurance decision is taken and assuming the adverse event does not occur. Consequently, the decision to take up insurance is then entirely determined in the loss domain (Sydnor, 2010).

Allocating resources to cyber insurance and cyber risk management is not a personal decision for an individual, but a decision made by

[1] Large studies (Bruhin et al., 2010) have estimated that up to 80% of people make decisions that are consistent with PT.

professionals and senior managers on behalf of its organization. However, in practice, due to high information and competence asymmetry, senior management often fails to discharge their fiduciary responsibility over cyber risk management, leaving the actual control to cybersecurity managers (Gale et al., 2022; Slapničar et al., 2023a). Instead of being involved, Gendron et al. (2020) found that senior managers and boards of directors often seek reassurance in reports from risk managers, who serve as "comfort givers". On the one hand, this suggests that the decision primarily rests with experts who are familiar with insurance products and feel capable of estimating cyber risks (Kunreuther and Pauly, 2004; de Smidt and Botzen, 2018). On the other hand, it is challenging to apply theories of individual decision making (either EUT or PT) to organizational (group) decision making. For example, a question arises about what represents the concept of wealth in group decision making, to which an individual decision maker refers in deriving the utility or value of an outcome. Agency theory suggests that managers do not automatically pursue the maximization of owners' wealth; however, this misalignment can be to a certain extent fixed by performance measurement and incentivizing of managers (Fama, 1980). The objective to maximize firm value (wealth) is incorporated in many incentive schemes for managers, aligning their personal objectives with firm objectives. Performance evaluation (budgets, peer comparisons, targets, relative incentives) are strongly associated with the formation of reference points that agents (managers) consider in their decision-making (Oblak et al., 2018). For simplicity, in this paper, we assume that there is no conflict of interest between agents and principals (owners). In other words, performance measurement and incentives make agents consider (owners') wealth (or a firm value) as their own reference value.

Prior findings suggest that biases are not diluted in group decision making about cybersecurity (Pfleeger and Caputo, 2012). In this journal, Pfleeger and Caputo (2012) argue that a deeper exploration of behavioral science literature can provide an empirical foundation for enhancing the quality and effectiveness of cybersecurity defenses. Specifically, they highlight the need for research about the framing effect (and PT) and various other behavioral science topics.

2.3. Prior literature on optimizing allocation of resources into cybersecurity controls and insurance

To the best of our knowledge, only a handful of studies investigate the optimization of resource allocation to cybersecurity controls and insurance. While they differ in the mathematical frameworks, they all use the normative EUT approach for decision-making.

Öğüt et al. (2011) analyzed the impact of risk correlation (when a cyber incident in one organization spills over to others) and unprovable loss on firm's cyber risk management strategies. They consider a CARA[2] type utility function but the model is aimed at optimizing public policy on cyber insurance uptake and also does not directly model the insurance premium as a function of cyber risk.

More recently, Marotta et al. (2017) provide a very good overview of the cyber insurance and cybersecurity controls space and lay out a general utility theory framework for optimizing the resource allocation. They argue that a risk-averse agent who chooses a certain security level by investing in cybersecurity controls could have a higher utility in paying a fixed insurance premium over bearing a random loss. They postulate that the utility depends on whether the premium is fair, that is, whether it reflects the loss probability and expected loss. However, they do not analytically derive the optimal solution of allocating resources to the two alternative cyber risk mitigation strategies: self-protective controls vs. insurance. Also, they do not consider PT.

Game theoretic models for cybersecurity resource allocation (Huseyin Cavusoglu and Yue, 2008; Rao et al., 2016; Rios Insua et al., 2021) have been proposed, too. These models consider a game between the organization and a specific malicious actor with intent, which limits the overall utility of their approach. (Marotta et al., 2017) lay out the conditions that would need to be modeled (information asymmetry, moral hazard, adverse selection, etc.) to consider a game between the insurer and the insured, however, they do not provide any analysis. When considering how to allocate resources to cybersecurity controls and cyber insurance, an organization needs to consider the collective risk due to all possible attacks over time regardless of who the attacker could be. Further, reducing cyber risk is also in the interest of the insurer and the premiums offered largely depend on the cyber risk of the insured as assessed by the insurer (Marotta et al., 2017; Öğüt et al., 2011). Therefore, we do not believe that game theoretic models are an appropriate choice for deriving the optimal resource allocation for the insured.

Not taking the game theoretic view, other studies have considered one of the mathematical optimization approaches instead. Chase et al. (2019) develop a stochastic optimization approach to joint cyber insurance and security-as-a-service provisioning in cloud computing. While their stochastic optimization algorithm is promising, they do not consider the interplay between the insurance costs and the security costs and do not consider any behavioral decision-making aspect including risk aversion.

Finally, Uuganbayar et al. (2021) propose a dynamic programming approach for optimal allocation of resources to different cybersecurity controls and cyber-insurance. Their approach also uses the EUT framework set out in Marotta et al. (2017) but only considers a competitive market with fair premiums and focuses on resource allocation to various cybersecurity controls that are considered independent of each other. However, it too does not consider the loss aversion aspects modeled using PT.

The relationship between the probability of a successful cyberattack and the cyber security expenditure was first modeled by Gordon and Loeb (2002) via the introduction of a security breach probability function $S(z, v)$.[3] In their model, z is the cyber security expenditure, and v is the *vulnerability* — the probability that a threat once realized would be successful. They propose two classes of probability functions: $S^I(z, v) = \frac{v}{(\alpha z+1)^\beta}$ and $S^{II}(z, v) = v^{(\alpha z+1)}$, where α and β are parameters for the productivity of the security investment. Both of these functions satisfy two realistic properties: a. Their first partial derivative with respect to z is negative (indicating that the probability of a successful attack decreases with increase in z,) and b. their second partial derivative with respect to z is positive (indicating that the rate of decrease in probability slows down with increase in z). Gordon and Loeb (2002) then find the optimal value of security investment that maximizes the expected net benefit from investment. However, this net benefit is considered purely in monetary terms. They do not consider a utility function to account for risk aversion and crucially, do not consider cyber insurance. This model was extended (Gordon et al., 2015) to include costs associated with externalities of the security breach rather than considering only the firm's internal costs.

Mazzoccoli and Naldi (2020) and Young et al. (2016) consider the cost of cyber insurance and use the GL functions to find an optimal mixed strategy solution that allocates resources to both cyber insurance and cyber security controls. However, these works have important drawbacks in that the cost of insurance premium is not based on cyber risk, and only the monetary cost is considered for optimization. They do not consider a utility function that could account for risk aversion and they also do not account for the costs associated with the loss of reputation, the loss of sensitive information, and the loss of customer data. As a result, their models lead to the conclusion that, in most cases, investing in security is not the best choice and that relying on cyber insurance alone is better.

[2] constant absolute risk aversion.

[3] Henceforth referred to simply as *GL function*.

Table 1
Literature review comparison.

Research paper	Considers cyber-insurance	Actuarial premiums	Risk curves	Utility fn./ EUT	Value fun./ PT	Jointly optimal solution
Gordon and Loeb (2002)	×	×	✓	×	×	×
Huseyin Cavusoglu and Yue (2008)	×	×	×	✓	×	×
Öğüt et al. (2011)	✓	×	×	✓	×	✓
Gordon et al. (2015)	×	×	✓	×	×	×
Young et al. (2016)	✓	×	✓	×	×	×
Rao et al. (2016)	×	×	×	✓	×	×
Marotta et al. (2017)	✓	✓	×	✓	×	×
Chase et al. (2019)	✓	×	×	×	×	✓
Mazzoccoli and Naldi (2020)	✓	×	✓	×	×	×
Rios Insua et al. (2021)	✓	×	×	✓	×	✓
Uuganbayar et al. (2021)	✓	✓	×	✓	×	✓
Skeoch (2022)	✓	×	✓	✓	×	×
This paper	✓	✓	✓	✓	✓	✓

Recently, Skeoch (2022) made the important leap to integrate GL functions into classical microeconomic analysis based on EUT. The author considers both CRRA type and CARA type utility functions and finds the optimal allocation of resources to cyber insurance and cyber security expenditures while considering that the probability of a successful cyber-attack is modeled using a GL function. While this work advances the research in the right direction, it has several limitations. The utility functions do not consider the wealth and the loss, similar to prior research, the cost of premium is considered independent of cyber risk and both expenditures are not optimized simultaneously. Instead, Skeoch (2022) finds the optimal cyber security investment assuming unspecified maximum cover and finds the optimal cyber insurance cover assuming the cyber security investment at the optimal level found by Gordon and Loeb (2002) (which does not use EUT).

A common limitation with the aforementioned works based on GL functions is that they determine optimal solutions by assuming specific values for the GL function parameters, which are not derived from real data. To the best of our knowledge, the only study to date which uses real data is (Paté-Cornell et al., 2018), who show how empirical risk curves can be constructed using a combination of available data and expert opinion. However, unlike our study, they do not provide a general mathematical model for risk curves. Also, their work does not concern optimal resource allocation to cyber insurance and cyber security, but instead focuses on how risk analysis models could be developed for cyber risk management.

Table 1 summarizes the above literature review in terms of six key model characteristics. It is worth noting that barring (Uuganbayar et al., 2021; Marotta et al., 2017) no other previous work has considered premiums that are actuarialy calculated, of which (Marotta et al., 2017) is only a survey paper that does not actually solve the optimal allocation problem. Aside from being the first work to consider optimal allocation based on PT, we are also the first EUT based optimization to consider actuarially derived premiums while considering a risk curve model and also jointly deriving optimal allocation to both cyber-security controls and cyber insurance.

3. Optimal allocation of resources

In this section, we describe the set up and derive the optimal allocation of resources to cybersecurity controls and cyber insurance from EUT and PT perspectives. An organization will likely face multiple cyber-attacks over a period of time, each of which could result in losses. When an organization considers resource allocation to cybersecurity controls and cyber insurance, they are expecting to protect against all possible attacks and losses. In the set-up below, for the ease of notation and description, we refer to *a successful cyber-attack* and *the loss* occurring from a successful cyber-attack, however, these are to be interpreted as *at least one successful cyber-attack* and the *collective loss* incurred from them, respectively. A successful cyber-attack is one that compromises availability, integrity, or confidentiality of data, resulting in significant adverse financial and non-financial consequences for an organization and its stakeholders.

Table 2
Notations.

$v(x)$	Value function of the organization, x is the net gain or loss
$w(p)$	Probability weighting function
C_{cs}	Cost of investing in cybersecurity controls
$\pi(C_{cs})$	Probability of a successful cyber-attack for a given cybersecurity controls cost
C_i	Cost of cyber insurance (insurance premium)
C_{tot}	Total cost $C_{cs} + C_i$
L	Loss due to a successful cyber-attack
W	Initial wealth
i_r	Insurance coverage ratio, $i_r = 1$ for a full coverage
D	Indemnity, $D = i_r L$
U	Utility function

Table 2 summarizes the notation detailed in this Section.

3.1. Set-up

Let W denote the initial wealth of the organization before investing in cybersecurity controls or cyber insurance and before any losses from a successful cyber-attack. Let L denote the loss from a successful cyber-attack and D, the indemnity of the insurance cover considered. The random variable loss (L) represents decision-makers' perception of damage (Marotta et al., 2017). Let $i_r = D/L$ be the insurance coverage ratio so that $i_r = 1$ indicates full insurance, $i_r = 0$ indicates no insurance, $i_r > 1$ denotes over-insurance and $i_r < 1$ denotes under-insurance. As discussed in Section 1 the case of over-insurance for cybersecurity is not realistic and therefore we exclude that case from further consideration.

Let C_i and C_{cs} denote the cost of cyber insurance and the cost of cybersecurity controls, respectively. We assume that investing in cybersecurity controls reduces the probability of a successful cyber-attack and therefore we denote this probability as $\pi(C_{cs})$ for a given C_{cs}. How this probability changes over values of C_{cs} defines, what we refer to as, a *risk curve*. The risk curve plays a key role in deriving the optimal allocation appropriate for a given situation and this is discussed in detail in Section 4. We assume that the insurance company will assess the cyber risk using $\pi(C_{cs})$ and derive the cost of the premium accordingly.

In a competitive market where the premiums are fair, we have (Marotta et al., 2017)

$$C_i = \pi(C_{cs})D = \pi(C_{cs})i_r L. \tag{6}$$

More generally though, an insurance premium will include a profit margin q, where q indicates the rate of profit. For example, $q = 0.05$ indicates a 5% profit margin. To date, there is no fixed standard for pricing cyber insurance, but as an example, insurance companies

Table 3
Net losses relative to W under different scenarios for PT.

Successful attack?	Full insurance	Under-insurance	No insurance
Yes	$-C_i - C_{cs}$	$-(1-i_r)L - C_i - C_{cs}$	$-L - C_{cs}$
No	$-C_i - C_{cs}$	$-C_i - C_{cs}$	$-C_{cs}$

Table 4
Net wealth after accounting for losses under different scenarios for EUT.

Successful attack?	Full insurance	Under-insurance	No insurance
Yes	$W - C_i - C_{cs}$	$W - (1-i_r)L - C_i - C_{cs}$	$W - L - C_{cs}$
No	$W - C_i - C_{cs}$	$W - C_i - C_{cs}$	$W - C_{cs}$

generally calculate the expected premium (fair) and add a rate q to make a profit. The cost of insurance is then given by

$$C_i = (1+q)\pi(C_{cs})D = (1+q)\pi(C_{cs})i_r L. \tag{7}$$

Note that the fair premium equation is a special case of Eq. (7) when $q = 0$. Eqs. (6) and (7) make it explicitly clear that C_i is a function of C_{cs} and therefore, the problem of finding optimal values of both C_i and C_{cs} reduces to finding the optimal C_{cs} given i_r, L, q and $\pi(C_{cs})$. The optimal value of C_{cs} will automatically determine the optimal value C_i using either of the two equations.

3.2. Prospect theory solution

In our analysis of the optimal allocation of resources between cybersecurity controls and insurance, we will adopt the initial wealth (or status quo) as a reference point (Sydnor, 2010; Hwang, 2021). Our decision is based on the belief that individuals code losses and gains ex-ante and that the uncertainty of the state of the world at the time of the decision is fundamental to risky decision-making, especially related to cyber risk. The status quo is the standard assumption in PT and is formalized in the third generation of PT (Schmidt et al., 2008). Moreover, wealth before insurance is also justified from the perspective of choosing a 'social reference point' based on comparison with others (who generally are not insured) (de Smidt and Botzen, 2018).

When using this baseline a decision-maker will always be in the loss domain. In the event of a successful cyber-attack, the net loss to an organization is $-C_i - C_{cs}$ if they had full insurance, $-(1-i_r)L - C_i - C_{cs}$ if they had under-insurance and $-L - C_{cs}$ if they had no insurance. In the event of no successful cyber-attack, the net loss will be $-C_i - C_{cs}$, for both the full and under insurance cases and $-C_{cs}$ for the no insurance case.

The net losses for different scenarios are summarized in Table 3

Using Table 3 and Eqs. (3), (4), (5) and (7) the overall value function of the organization if they decide to buy cyber insurance is be given by

$$\begin{aligned} V &= w(\pi(C_{cs}))v(-(1-i_r)L - C_i - C_{cs}) + w(1-\pi(C_{cs}))v(-C_i - C_{cs}), \\ &= -\lambda\{w(\pi(C_{cs}))\left[L - i_r L(1-(1+q)\pi(C_{cs})) + C_{cs}\right]^{\alpha} \\ &\quad + w(1-\pi(C_{cs}))[(1+q)\pi(C_{cs})i_r L + C_{cs}]^{\alpha}\}. \end{aligned} \tag{8}$$

In case of full insurance ($i_r = 1$) the value function simplifies to

$$V = -\lambda\left[(1+q)\pi(C_{cs})L + C_{cs}\right]^{\alpha}(w(\pi(C_{cs})) + w(1-\pi(C_{cs}))). \tag{9}$$

If the organization did not buy insurance ($i_r = 0$) then

$$\begin{aligned} V &= -\lambda\{w(\pi(C_{cs}))|-L - C_{cs}|^{\alpha} + w(1-\pi(C_{cs}))|-C_{cs}|^{\alpha}\}, \\ &= -\lambda\{w(\pi(C_{cs}))[L + C_{cs}]^{\alpha} + w(1-\pi(C_{cs}))[C_{cs}]^{\alpha}\} \end{aligned} \tag{10}$$

The optimal solution for resource allocation can be found by first finding C_{cs}^* that maximizes the overall value function V and then finding the corresponding C_i^* using Eq. (7).

3.3. Expected utility theory solution

EUT considers the effect of a decision on net wealth after accounting for any gains/losses. These are summarized in Table 4 for different scenarios.

Using Table 4, the CRRA utility function (2), and Eqs. (1) and (7) the expected utility function of the organization if it decides to buy cyber insurance is given by

$$\begin{aligned} E[U] &= \pi(C_{cs})(W - (1-i_r)L - C_i - C_{cs})^r + (1-\pi(C_{cs}))(W - C_i - C_{cs})^r, \\ &= \pi(C_{cs})(W - L - i_r L(1-(1+q)\pi(C_{cs})) - C_{cs})^r \\ &\quad + (1-\pi(C_{cs}))(W - (1+q)\pi(C_{cs})i_r L - C_{cs})^r. \end{aligned} \tag{11}$$

In case of full insurance ($i_r = 1$) the function simplifies to

$$\begin{aligned} E[U] &= \pi(C_{cs})(W - C_i - C_{cs})^r + (1-\pi(C_{cs}))(W - C_i - C_{cs})^r, \\ &= (W - (1+q)\pi(C_{cs})L - C_{cs})^r. \end{aligned} \tag{12}$$

If the organization did not buy insurance ($i_r = 0$) then

$$E[U] = \pi(C_{cs})(W - L - C_{cs})^r + (1-\pi(C_{cs}))(W - C_{cs})^r. \tag{13}$$

Now, we consider the special case of risk neutral decision-maker, where $r = 1$. A risk-neutral attitude indicates that the preferred decision will be solely based on superior expected returns and will not be weighed by the risk involved. For this approach, if the organization buys cyber insurance, the expected utility function simplifies to

$$\begin{aligned} E[U] &= \pi(C_{cs})(W - (1-i_r)L - C_i - C_{cs}) + (1-\pi(C_{cs}))(W - C_i - C_{cs}), \\ &= W - \pi(C_{cs})(1-i_r)L - C_i - C_{cs}, \\ &= W - \pi(C_{cs})(1-i_r)L - (1+q)\pi(C_{cs})i_r L - C_{cs}, \\ &= W - \pi(C_{cs})L(1+qi_r) - C_{cs}. \end{aligned} \tag{14}$$

In case of full insurance ($i_r = 1$) the expected utility becomes

$$E[U] = W - \pi(C_{cs})L(1+q) - C_{cs}.$$

If the organization did not buy insurance ($i_r = 0$) then

$$E[U] = W - C_{cs} - \pi(C_{cs})L. \tag{15}$$

A unique consequence of the rational behavior modeled here is that, if the organization buys insurance with a fair premium, which means $q = 0$, the expected utility function (14) reduces to (15), when it does not buy the insurance. This makes perfect sense since, by definition, the cost of the fair premium is exactly equal to the expected loss due to an attack in the event of no insurance.

The optimal solution for resource allocation can be found by first finding C_{cs}^* that maximizes the expected utility and then finding the corresponding C_i^* using Eq. (7).

3.4. Comparing EUT and PT solutions

3.4.1. General case

It can be seen from Eqs. (2) and (3) that both the utility function and the value function are similar in their functional forms. The utility function $(W - x)^r$ is a polynomial of degree $r > 0$, and as such, a monotonic function of x. This suggests that the optimal allocation — given by the stationary point of the expected utility function (1) — will be largely influenced by the probabilities $p(x)$. For parameters r we can postulate the following.

Conjecture 1. *The risk aversion parameter r, by itself, will have a minor effect, if any, on the stationary point of the expected utility function.*

The value function for PT is also a polynomial of degree α since it can be expressed as $-\lambda x^{\alpha}$, where $\lambda = -1$, if $x > 0$ and $x = |x|$, if $x < 0$. The optimal allocation is given by the stationary point of the overall value function (5) for PT. From Eqs. (8), (9) and (10), it is clear that the loss aversion parameter λ will have no effect on the optimal value of C_{cs}. Regarding the overall value function V in Eq.

(8) note that as the insurance coverage goes down, $i_r \downarrow$, the loss in case of a successful attack goes up, $L - i_r L(1-(1+q)\pi(C_{cs})) + C_{cs} \uparrow$ and the cost in case of no such attack goes down, $(1+q)\pi(C_{cs})i_r L + C_{cs} \downarrow$. The weighting function over-weights small probabilities and under-weights higher ones. Typically, we would expect $\pi(C_{cs})$ to be small and therefore $1-\pi(C_{cs})$ to be larger. Thus, it can be seen that as the insurance coverage decreases, the component corresponding to a successful cyber-attack $w(\pi(C_{cs}))\left[L - i_r L(1-(1+q)\pi(C_{cs})) + C_{cs}\right]^{\alpha}$ will have an increasing influence on the overall value function. This influence will further increase as the diminishing sensitivity parameter α increases (indicating that diminishing sensitivity is milder). Therefore we postulate the following.

Conjecture 2. *The diminishing sensitivity parameter α, could have substantial effect on the stationary point of the overall value function, especially as the insurance coverage ratio i_r decreases. For a given i_r, as α increases, so also will the optimal value C^*_{cs} of cybersecurity controls expenditure.*

Finally, note that as the probability weighting parameter increases to 1, $\beta \uparrow 1$, the non-linearity in the probability weights reduces so that when $\beta = 1$, we have $w(p) = p$. Consequently, as $\beta \uparrow 1$, the decision weight on $\pi(C_{cs})$ will decrease reducing the influence of the component corresponding to a successful cyber-attack $w(\pi(C_{cs}))\left[L - i_r L(1-(1+q)\pi(C_{cs})) + C_{cs}\right]^{\alpha}$. Therefore, we postulate the following.

Conjecture 3. *The probability weighting parameter β causes higher allocation of resources to C_{cs} in PT relative to EUT. Increasing the value of β (up to a maximum of 1) will reduce the allocation to C_{cs}.*

We will use numerical examples to investigate if Conjectures 1, 2 and 3 hold for different risk curves.

An exception to Conjecture 2 is the case of full insurance ($i_r = 1$) since the overall value equation for that case, see Eq. (9), does not include L. We discuss this case in detail below.

3.4.2. Special case of full insurance, $i_r = 1$

For the full insurance case, we can mathematically show that the optimal cybersecurity controls expenditure under PT will always be less than that under EUT. Further, since the higher expenditure in cybersecurity controls is expected to reduce the risk, the insurance premium under PT will be greater than that under EUT.

First, we will prove a mathematical fact that will be used in proving the main results.

Proposition 1. *When $0 < p \le 0.5$, $w(p) + w(1-p)$ is a monotonically decreasing function with respect to p.*

Proof. Because $w(p) + w(1-p) = \frac{p^\beta}{(p^\beta+(1-p)^\beta)^{1/\beta}} + \frac{(1-p)^\beta}{(p^\beta+(1-p)^\beta)^{1/\beta}}$. Let $x = p^\beta + (1-p)^\beta$, obviously $x > 1$ when $0 < p \le 0.5$, then $w(p) + w(1-p) = \frac{x}{x^{1/\beta}} = x^{1-1/\beta}$ is a monotonically decreasing function with respect to x, which is $\frac{d[w(p)+w(1-p)]}{dx} < 0$. When $\beta < 1$ and $0 < p \le 0.5$, $\frac{dx}{dp} > 0$. By the chain rule, $\frac{d[w(p)+w(1-p)]}{dx}\frac{dx}{dp} < 0$, which means $w(p) + w(1-p)$ is a monotonically decreasing function with respect to p.

Let $C_{EUT} = \text{argmax}_{C_{cs}} E[U]$, $C_{PT} = \text{argmax}_{C_{cs}} V$. Define $\pi(C_{cs})$ is a non-increasing function with respect to C_{cs} and for any C_{cs}, $0 < \pi(C_{cs}) \le 0.5$.

Theorem 1. *When $i_r = 1$, if $E[U]$ only has one stationary point, then $C_{PT} < C_{EUT}$.*

Proof. Because $E[U]$ only has one stationary point and $C_{EUT} = \text{argmax}_{C_{cs}} E[U]$, we have

$$\frac{\partial E[U(C_{EUT})]}{\partial C_{cs}} = -1 - \pi'(C_{EUT})(1+q)L = 0. \tag{16}$$

Consider the value of $\frac{\partial V(C_{EUT})}{\partial C_{cs}}$

$$\begin{aligned} &= -\lambda\{\alpha[\pi(C_{EUT})(1+q)L + C_{EUT}]^{\alpha-1}[\pi'(C_{EUT})(1+q)L + 1] \\ &\quad \times [w(\pi(C_{EUT})) + w(1-\pi(C_{EUT}))] \\ &\quad + [\pi(C_{EUT})(1+q)L + C_{EUT}]^{\alpha}\frac{\partial[w(\pi)+w(1-\pi)]}{\partial\pi}\frac{\partial\pi}{\partial C_{cs}}|_{C_{cs}=C_{EUT}}\}. \end{aligned} \tag{17}$$

By (16), the first part of (17) is 0, so (17) can be simplified to

$$\frac{\partial V(C_{EUT})}{\partial C_{cs}} = -\lambda\{[\pi(C_{EUT})(1+q)L + C_{EUT}]^{\alpha}\frac{\partial[w(\pi)+w(1-\pi)]}{\partial\pi}\frac{\partial\pi}{\partial C_{cs}}|_{C_{cs}=C_{EUT}}\}.$$

By *Proposition* 1, and for any C_{cs}, $\frac{\partial\pi}{\partial C_{cs}} \le 0$, we know that $\frac{\partial[w(\pi)+w(1-\pi)]}{\partial\pi}\frac{\partial\pi}{\partial C_{cs}}|_{C_{cs}=C_{EUT}} \ge 0$. But (16) shows that $\pi'(C_{EUT}) \ne 0$, so $\frac{\partial[w(\pi)+w(1-\pi)]}{\partial\pi}\frac{\partial\pi}{\partial C_{cs}}|_{C_{cs}=C_{EUT}}\} > 0$. Since $[\pi(C_{EUT})(1+q)L + C_{EUT}]^{\alpha} > 0$, we have $\frac{\partial V(C_{EUT})}{\partial C_{cs}} < 0$, which means V is already decreasing at C_{EUT}. So

$$C_{PT} = \underset{C_{cs}}{\text{argmax}}\, V < C_{EUT}.$$

Theorem 2. *When $i_r = 1$, if $E[U]$ only has one stationary point, then $C_{iEUT} < C_{iPT}$.*

Proof. By Theorem 1, we have $C_{PT} < C_{EUT}$. Because

$$C_{iEUT} = \pi(C_{EUT})(1+q)L, C_{iPT} = \pi(C_{PT})(1+q)L,$$

and $\pi'(C_{EUT}) \ne 0$, $\pi(C_{cs})$ is a non-increasing function with respect to C_{cs}, then $C_{iEUT} < C_{iPT}$.

There will be some cases in which the total cost of EUT is equal to PT, which is $C_{EUT} + C_{iEUT} = C_{PT} + C_{iPT}$. Expanding it we have

$$C_{EUT} + \pi(C_{EUT})(1+q)L = C_{PT} + \pi(C_{PT})(1+q)L. \tag{18}$$

By Theorems 1 and 2, we know that $C_{EUT} > C_{PT}$ and $C_{iEUT} < C_{iPT}$, so if L, q and π satisfy the following condition

$$C_{EUT} - C_{PT} = (1+q)L[\pi(C_{PT}) - \pi(C_{EUT})], \tag{19}$$

then the total cost of EUT is equal to PT.

4. Risk curves

4.1. Modeling the risk curve

Let π denote the probability of (at least one) successful cyber-attack. With a risk curve $\pi = \pi(C_{cs})$ we model how this probability changes with investment in cybersecurity controls. We make some basic assumptions that are consistent with the framework recommended by Marotta et al. (2017).

1. $\pi(C_{cs})$ is monotonically non-decreasing, that is, π will either decrease or stay constant with increase in C_{cs}. This implies that the first derivative of $\pi(C_{cs})$ with respect to C_{cs} should be ≤ 0.
2. Many software products and IT systems (including network as well as cloud, etc.) come with security measures built into them. As a result, the baseline risk $\pi(C_{cs} = 0) \le 1$.
3. $\pi(C_{cs}) > 0$, that is, the probability of (at least one) successful cyber-attack can never be completely eliminated.
4. Some threats are easier to protect against but some others would require increasingly expensive protection. Therefore, while initial investment in C_{cs} might yield significant reduction in $\pi(C_{cs})$, the rate of reduction will slow down with subsequent increases. This implies that the second derivative of $\pi(C_{cs})$ should be ≥ 0.

As discussed in Section 2.3, the only previous attempt to mathematically model this relationship was in Gordon and Loeb (2002), who called it a probability breach function and proposed two possible functional forms. Both of these are functions of vulnerability v (Gordon and Loeb, 2002). The subsequent literature has assumed a fixed value of v that has been used to derive mathematical results. However, vulnerability can only be defined for a specific control and with respect to a specific threat. Since there are numerous controls and various types of threats, it is not appropriate to assume that a single value of vulnerability can be considered an accurate measure for the whole system. Furthermore, even if it was possible to derive a single accurate value of vulnerability, it would need to be different for each organization due to the uniqueness of their circumstances.

Every organization will have a unique risk curve. This is because both the cost of cybersecurity controls and the probability of a breach depend on a multitude of factors, including the size of the organization, the nature of their operations, the specifics of the IT systems and other factors.

We believe that the model for the risk curve should be flexible, so that a bespoke risk curve could be derived for every organization. We propose the following functional form to model a risk curve.

$$\pi(C_{cs}) = \gamma \exp(-\beta C_{cs}), \tag{20}$$

where $0 < \gamma \leq 1$ represents the probability of (at least one) successful cyber-attack when $C_{cs} = 0$ (baseline risk) and $\beta > 0$ governs the rate at which this probability will reduce with increase in C_{cs}. It can be seen that the first derivative with respect to Ccs, $\pi'(C_{cs}) = -\beta\gamma \exp(-\lambda C_{cs}) < 0$, implying that the probability will decrease with increase in C_{cs} and the second derivative $\pi''(C_{cs}) = \beta^2\gamma \exp(-\lambda C_{cs}) > 0$, implying that this rate of decrease will slow down as C_{cs} increases.

Note that by taking log on both sides of (20), we get

$$\log \pi(C_{cs}) = \log \gamma - \beta \times C_{cs}.$$

Therefore, estimating the parameters of the risk curve is straightforward since it is simply a multiplicative linear regression of $\pi(C_{cs})$ on C_{cs}.

4.2. Estimating the parameters

Fitting a bespoke risk function for an organization requires two key inputs. The costs C_{cs} of cybersecurity controls and the corresponding probabilities $\pi(C_{cs})$. The quotes from the vendors can provide accurate information about costs. However, estimating the probabilities is challenging. As illustrated in Paté-Cornell et al. (2018), statistical analysis of available data in combination with Bayesian methods to incorporate expert judgment can be used to derive an empirical risk curve. Databases and catalogs of known threats, as well as information from vendors on the level of protection their products are known to provide, could also be utilized to estimate $\pi(C_{cs})$ (Rios Insua et al., 2021).

Table 5 provides hypothetical values of C_{cs} and $\pi(C_{cs})$ for Organization A. Thus, the organization estimates that its default risk is 0.2 and that investing up to \$10,000 in C_{cs} will reduce this probability down to 0.01, with further investments yielding only marginal reductions in this probability. Note, however, that these values are mere estimates. Fitting a multiplicative linear regression model will allow us to model the general trend and thus provide a prediction of $\pi(C_{cs})$ that accounts for some of the uncertainty in the reported values. The fitted risk curve is

$$\pi(C_{cs}) = 0.2055 \exp(-0.306295 \times C_{cs}) = 0.2055 \times (0.7362)^{C_{cs}},$$

and is shown in Fig. 1. The risk curve model predicts that the baseline probability will be 0.2055 and that for every additional \$1000, this probability will be 0.7362 of what it was before. In other words, for every additional \$1000 invested in cybersecurity controls, $\pi(C_{cs})$ is expected to reduce by about 26.4%. Thus, fitting this risk curve can provide a meaningful insight to the decision-maker.

Table 5
The hypothetical C_{cs} and $\pi(C_{cs})$ for organization A.

C_{cs} (in \$′000)	π (C_{cs})
0	0.2
1	0.15
2	0.11
2.5	0.095
4	0.06
7.5	0.02
10	0.01
14	0.003
18	0.001
22	0.0002

Now consider a hypothetical data and fitted risk curve (*continuous line*) for Organization B as shown in Fig. 2. Here, $\pi(C_{cs})$ displays a slightly different pattern where the probabilities initially decline rapidly with increases in C_{cs} but then taper off, until a significant further increase in C_{cs} causes $\pi(C_{cs})$ to decline further and then taper off again. It can be seen that the fit of the risk curve can be improved to more accurately predict the curve as well as the baseline probability. This is because $\exp(-\beta)$ models a constant rate of decline (which we estimated to be about 26.4% for π_1), however, for Organization B, the tapering nature of $\pi(C_{cs})$ suggests that the rate of decline is not constant.

We can now introduce a generalization of the risk curve model (20). More generally, the risk curve could be modeled as

$$\pi(C_{cs}) = \gamma \exp(f(C_{cs})), \tag{21}$$

where $f(C_{cs})$ is any twice differentiable function that satisfies the following properties: *i.* $f(0) = 0$, *ii.* $df/dC_{cs} < 0$ over the range of C_{cs} under consideration, and *iii.* $d^2f/dC_{cs}^2 > 0$ over the range of C_{cs} under consideration. As also seen in Fig. 2, a better fit is provided in this case by a quadratic function $f(C_{cs}) = \beta_1 C_{cs} + \beta_2 C_{cs}^2$, which also satisfies the above three conditions for the range of C_{cs} considered. Here, the positive coefficient β_2 allows us to model a slowing rate of decline in $\pi(C_{cs})$ as C_{cs} continues to increase. This functional form allows us to model a very challenging cyber-security environment where some level of cyber risk is rather persistent despite further investment in cyber security controls. Note, once again, this functional form is only valid for the range of C_{cs} over which conditions *ii* and *iii* are satisfied.

5. Numerical comparisons

The risk curves π_1 and π_2 model two different risk scenarios. Since each organization will have a unique risk curve, we consider two further risk curves π_3 and π_4 to include scenarios wither much higher baseline probability and slow or faster rate of declines in those. These are as follows:

π_1 : baseline prob: 0.2055, slow rate of decline: 26.4%.

π_2 : baseline prob: 0.119, slowing rate of decline given by the quadratic.

π_3 : baseline prob: 0.37, slow rate of decline: 26.4%.

π_4 : baseline prob: 0.37, faster rate of decline: 54.8%.

We now run numerical comparisons to illustrate how the optimal resource allocation considering the PT and the EUT perspectives might differ for the four different risk curves shown in Fig. 3 and to investigate the three Conjectures. This will provide a better understanding of the modeling inputs that influence the optimal allocation. We find the

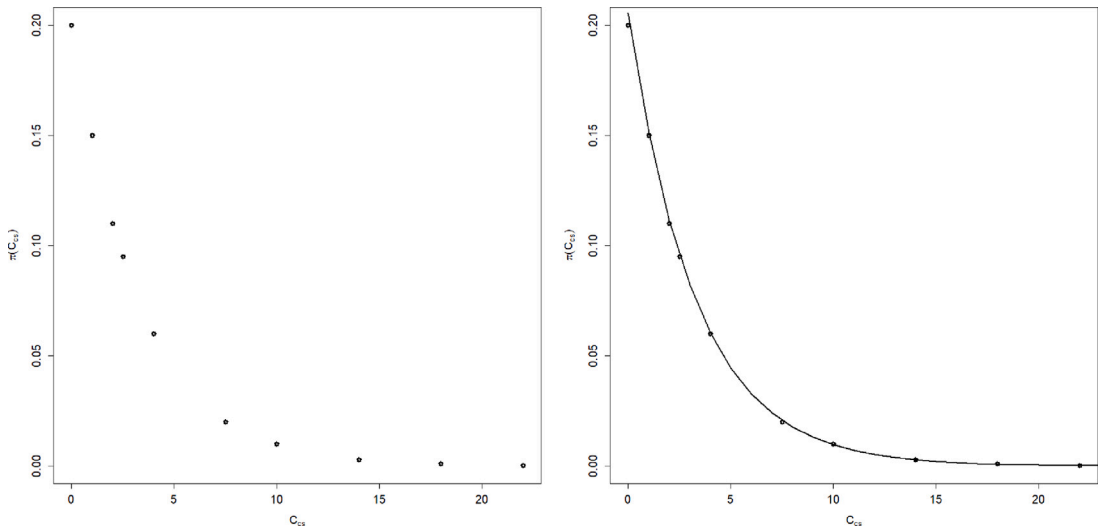

Fig. 1. π_1 : The hypothetical data (*left*) and the fitted risk curve (*right*) for Organization A. The fitted curve is $\pi(C_{cs}) = 0.2055\exp(-0.306295 \times C_{cs})$.

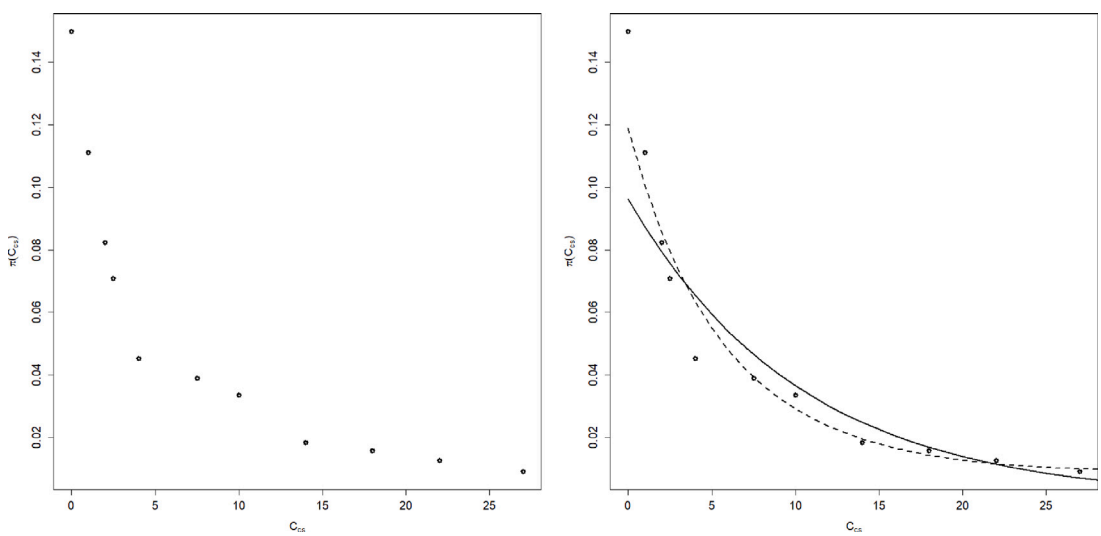

Fig. 2. π_2 : The hypothetical data (*left*) and fitted risk curves (*right*) for Organization B. The *continuous line* fitted curve is $\pi(C_{cs}) = 0.0964\exp(-0.0969 \times C_{cs})$. The improved *dashed line* fitted curve is $\pi(C_{cs}) = 0.119\exp(-0.169 \times C_{cs} + 0.0028 \times C_{cs}^2)$.

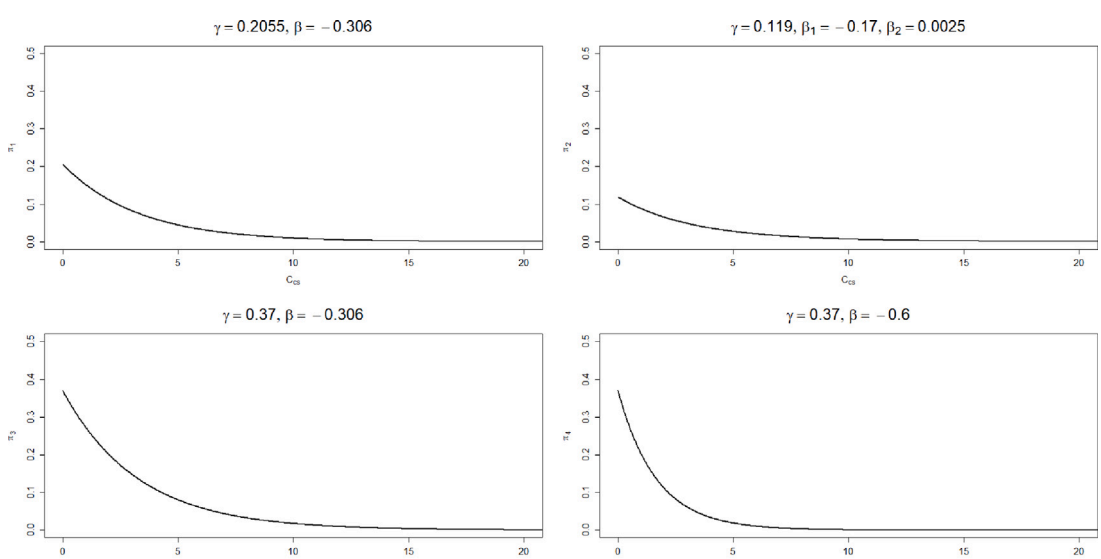

Fig. 3. The four risk curves we consider for numerical examples.

optimal solutions for three distinct cases: full insurance ($i_r = 1$), under insurance ($i_r = 0.8$) and no insurance ($i_r = 0$).

We assume that $W = 10,000, L = 400$, based on the empirical findings that losses of owners' wealth after a cyber breach range up to 4% of market capitalization as reported by current research (Kamiya et al., 2021; Walton et al., 2021). We first derive the optimal allocation for fair premiums (profit margin $q = 0$) and then also for profit margin $q = 0.3$ (30%) to understand how the profit margin could affect this allocation. Thus, we derive optimal solutions for both fair and non-fair premiums while assuming that the losses due to successful cyber-attacks are 4% of the initial wealth.

5.1. Investigating Conjectures 1, 2 and 3

For PT, we consider the median values from Tversky and Kahneman (1992), $\alpha = 0.88, \beta = 0.65$ and $\lambda = 2.25$ as the base case.

To investigate Conjecture 1, we find the optimal solutions for two cases: risk neutral ($r = 1$) and risk averse. Keeping in mind the similarity in expressions for EUT and PT, we choose the risk aversion parameter r to be equal to the base case value of α in PT. That is, we consider the cases of $r = 0.88$ and $r = 1$.

To investigate Conjecture 2, we consider different values of α. Note that $\alpha = 1$ indicates no diminishing sensitivity to the increasing value of losses. Bruhin et al. (2010) found that while α could be as low as 0.25 (indicating a very strong level of diminishing sensitivity) in some experiments, in most cases, it was found to be between 0.5 and 1. We consider the median value of α to be a *moderate* level and consider two PT variations: *high level of diminishing sensitivity* with $\alpha = 0.80$ and *low level of diminishing sensitivity* with $\alpha = 0.95$.

The results in Table 6 provide evidence that Conjecture 1 could be true. That is, regardless of the risk curve and the level of insurance, the optimal resource allocation of investments in cybersecurity controls and cyber insurance considering the EUT perspective only changes a little, if at all, with change in the risk aversion coefficient r.

The allocation to C_{cs} under the PT perspective seems to increase as α increases and especially so, as i_r decreases. These results provide a clear indication that Conjecture 2 could be true. That is, the diminishing sensitivity parameter α has a substantial effect on the stationary point of the overall value function, especially as the insurance coverage ratio i_r decreases.

To investigate Conjecture 3, we now repeat the PT allocations for the case of linear weights ($\beta = 1$.). Table 7 shows that when the probability weighting is linear, $\beta = 1$ (same as in EUT), the optimal resource allocation to C_{cs} under the PT perspective is significantly lower than when $\beta = 0.65$. Thus, the results indicate that the probability weighting parameter β being less than 1 (non-linear weights) causes higher allocation of resources to C_{cs} under the PT perspective relative to the allocation under the EUT perspective. That is, Conjecture 3 also seems to hold true.

When $\alpha = 0.95$, the sensitivity to large losses diminishes by a lesser extent and therefore the decision weight has a higher leverage to influence the optimal allocation of resources. On the other hand, when $\alpha = 0.8$, the sensitivity to larger losses diminishes by a much greater extent, countering the effect of decision weights. This leads to a much lower expenditure on C_{cs}, which is closer to the allocation under EUT.

Finally, note that when $\alpha = 1, \beta = 1$ (that is, there is no diminishing sensitivity and no probability weights), the optimal allocation using PT is identical to that using EUT.

5.2. Insurance related factors

5.2.1. Level of insurance

As mathematically proven in Section 3.4, the numerical results show that for the case of full insurance, the optimal investment in cybersecurity controls under PT is lower than that under EUT. Consequently, the cyber insurance cost under PT is greater than that under EUT. However, in almost every case, the total investment under PT and EUT is almost exactly the same when considering the full insurance scenario.

However, as discussed earlier, the case of under-insurance is more prevalent in practice. The results indicate that for partial insurance, a decision-maker tends to allocate more resources towards C_{cs} if they behave in line with PT than if they behave in line with EUT. While this additional expenditure results in lower insurance costs C_i, the total expenditure C_{tot} under the PT perspective is higher than under the EUT perspective. Moreover, the additional expenditure under PT increases as the level of insurance decreases, so that for the no-insurance case, the cyber security expenditure under PT is considerably higher than that under EUT. Thus, the EUT perspective seems to lead to lower overall investment in cybersecurity than the PT perspective.

5.2.2. Profit margin q

Results in Table 8 show that when the premiums include a profit margin, the broad trends noted so far remain unchanged, yet when compared against Table 6, the resource allocation changes. Since insurance premiums are now more expensive, both EUT and PT now

Table 6
Optimal C_{cs}, C_i and C_{tot} for $\pi_1, \pi_2, \pi_3, \pi_4$ when $q = 0$.

Risk curve	$i_r = 0$			$i_r = 0.8$			$i_r = 1$		
π_1	C_{cs}	C_i	C_{tot}	C_{cs}	C_i	C_{tot}	C_{cs}	C_i	C_{tot}
PT, $\alpha = 0.80$	14.00	0	14.00	11.36	2.03	13.39	10.33	3.48	13.81
PT, $\alpha = 0.88$	15.06	0	15.06	11.54	1.92	13.47	10.35	3.46	13.81
PT, $\alpha = 0.95$	15.95	0	15.95	11.71	1.83	13.54	10.36	3.45	13.81
EUT, $r = 0.88$	10.55	0	10.55	10.54	2.61	13.15	10.54	3.27	13.81
EUT, $r = 1$	10.54	0	10.54	10.54	2.61	13.15	10.54	3.27	13.81
π_2									
PT, $\alpha = 0.80$	14.17	0	14.17	12.46	6.75	19.21	11.46	9.42	20.88
PT, $\alpha = 0.88$	15.98	0	15.98	12.67	6.60	19.27	11.50	9.38	20.88
PT, $\alpha = 0.95$	17.46	0	17.46	12.85	6.47	19.33	11.52	9.35	20.88
EUT, $r = 0.88$	11.86	0	11.86	11.84	7.22	19.06	11.84	9.03	20.87
EUT, $r = 1$	11.84	0	11.84	11.84	7.22	19.06	11.84	9.03	20.87
π_3									
PT, $\alpha = 0.80$	16.02	0	16.02	13.28	2.03	15.32	12.22	3.51	15.74
PT, $\alpha = 0.88$	17.03	0	17.03	13.46	1.93	15.38	12.24	3.49	15.74
PT, $\alpha = 0.95$	17.89	0	17.89	13.62	1.84	15.45	12.26	3.47	15.74
EUT, $r = 0.88$	12.47	0	12.47	12.46	2.61	15.08	12.46	3.27	15.73
EUT, $r = 1$	12.46	0	12.46	12.46	2.61	15.08	12.46	3.27	15.73
π_4									
PT, $\alpha = 0.80$	9.75	0	9.75	8.09	0.92	9.02	7.38	1.76	9.15
PT, $\alpha = 0.88$	10.35	0	10.35	8.22	0.85	9.08	7.39	1.76	9.15
PT, $\alpha = 0.95$	10.86	0	10.86	8.34	0.79	9.14	7.40	1.75	9.15
EUT, $r = 0.88$	7.48	0	7.48	7.48	1.33	8.81	7.48	1.67	9.14
EUT, $r = 1$	7.48	0	7.48	7.48	1.33	8.81	7.48	1.67	9.14

Table 7
Optimal C_{cs}, C_i and C_{tot} for PT for $\pi_1, \pi_2, \pi_3, \pi_4$ when $\beta = 1$ and $q = 0$..

π_1	$i_r = 0$			$i_r = 0.8$			$i_r = 1$		
	C_{cs}	C_i	C_{tot}	C_{cs}	C_i	C_{tot}	C_{cs}	C_i	C_{tot}
PT, $\alpha = 0.80$	8.69	0	8.69	10.39	2.73	13.13	10.54	3.27	13.81
PT, $\alpha = 0.88$	9.45	0	9.45	10.45	2.69	13.14	10.54	3.27	13.81
PT, $\alpha = 0.95$	10.1	0	10.1	10.50	2.65	13.15	10.54	3.27	13.81
π_2									
PT, $\alpha = 0.80$	8.37	0	8.37	11.61	7.41	19.02	11.84	9.03	20.87
PT, $\alpha = 0.88$	9.81	0	9.81	11.70	7.34	19.04	11.84	9.03	20.87
PT, $\alpha = 0.95$	11.01	0	11.01	11.78	7.27	19.05	11.84	9.03	20.87
π_3									
PT, $\alpha = 0.80$	10.74	0	10.74	12.32	2.73	15.05	12.46	3.27	15.73
PT, $\alpha = 0.88$	11.44	0	11.44	12.37	2.68	15.06	12.46	3.27	15.73
PT, $\alpha = 0.95$	12.04	0	12.04	12.42	2.64	15.07	12.46	3.27	15.73
π_4									
PT, $\alpha = 0.80$	6.44	0	6.44	7.39	1.41	8.79	7.48	1.67	9.14
PT, $\alpha = 0.88$	6.86	0	6.86	7.42	1.38	8.80	7.48	1.67	9.14
PT, $\alpha = 0.95$	7.22	0	7.22	7.45	1.35	8.81	7.48	1.67	9.14

Table 8
Optimal C_{cs}, C_i and C_{tot} for $\pi_1, \pi_2, \pi_3, \pi_4$ when $q = 0.3$.

Risk curve	$i_r = 0$			$i_r = 0.8$			$i_r = 1$		
π_1	C_{cs}	C_i	C_{tot}	C_{cs}	C_i	C_{tot}	C_{cs}	C_i	C_{tot}
PT, $\alpha = 0.80$	14.00	0	14.00	12.00	2.17	14.17	11.20	3.47	14.67
PT, $\alpha = 0.88$	15.06	0	15.06	12.16	2.07	14.23	11.22	3.45	14.67
PT, $\alpha = 0.95$	15.95	0	15.95	12.3	1.98	14.28	11.24	3.43	14.67
EUT, $r = 0.88$	10.55	0	10.55	11.24	2.74	13.98	11.40	3.27	17.67
EUT, $r = 1$	10.54	0	10.54	11.24	2.74	13.98	11.40	3.27	17.67
π_2									
PT, $\alpha = 0.80$	14.17	0	14.17	13.83	7.61	21.44	13.18	10.16	23.34
PT, $\alpha = 0.88$	15.98	0	15.98	14.01	7.47	21.48	13.22	10.12	23.34
PT, $\alpha = 0.95$	17.46	0	17.46	14.16	7.36	21.52	13.24	10.10	23.34
EUT, $r = 0.88$	11.86	0	11.86	13.24	8.08	21.32	13.55	9.78	23.33
EUT, $r = 1$	11.84	0	11.84	13.24	8.08	21.32	13.55	9.78	23.33
π_3									
PT, $\alpha = 0.80$	16.02	0	16.02	13.92	2.17	16.09	13.10	3.50	16.6
PT, $\alpha = 0.88$	17.03	0	17.03	14.07	2.08	16.15	13.12	3.48	16.6
PT, $\alpha = 0.95$	17.89	0	17.89	14.21	1.99	16.20	13.14	3.46	16.6
EUT, $r = 0.88$	12.47	0	12.47	13.16	2.74	15.90	13.32	3.28	16.6
EUT, $r = 1$	12.46	0	12.46	13.16	2.74	15.90	13.32	3.28	16.6
π_4									
PT, $\alpha = 0.80$	9.75	0	9.75	8.38	1.01	9.39	7.83	1.75	9.58
PT, $\alpha = 0.88$	10.35	0	10.35	8.51	0.93	9.44	7.84	1.74	9.58
PT, $\alpha = 0.95$	10.86	0	10.86	8.61	0.88	9.49	7.84	1.74	9.58
EUT, $r = 0.88$	7.48	0	7.48	7.84	1.40	9.23	7.91	1.67	9.58
EUT, $r = 1$	7.48	0	7.48	7.84	1.40	9.23	7.91	1.67	9.58

point to a higher investment in cybersecurity controls to reduce the risk further and thus prevent the corresponding premiums from being too expensive.

5.3. Risk curve matters

All of the general trends described so far that contrast PT against EUT are valid regardless of the nature of the risk curve. At the same time, the shape of the risk curve influences the resource allocation in three different ways regardless of the strategy: EUT or PT.

- *Baseline risk affects C_{cs}:* When the baseline risk is higher (π_3), the decision-makers that behave in line with either PT or EUT tend to invest more in cybersecurity controls than when the baseline risk is lower (π_1 or π_2), but we see differing costs invested in cyber insurance depending on how quickly the risk reduces with further investment.
- *How quickly the risk reduces affects both C_{cs} and C_i :* Investments in both cybersecurity controls and insurance are much higher, when the risk reduces slowly with the investment in cybersecurity controls (π_1 and π_3) versus when it reduces quickly (π_4), for both PT and EUT.
- *Slowing rate of decline leads to higher C_i* : A slowing rate of decline in the risk curve (π_2) leads to much higher investment in insurance than when risk curves have a constant rate of decline (π_1, π_3 or π_4), even if the baseline risk is much smaller (π_2).

5.4. Finding the optimal allocation for an organization

If an organization was given the three insurance options discussed, which option will be the most favored considering the PT and EUT perspectives? We find that regardless of the risk curve, considering PT always seemed to point to the full insurance case as the best option. Further, the overall value was the lowest for the no insurance option, whereas the difference in the overall value between the partial insurance and the full insurance options was negligible. This suggests that a decision-maker that behaves according to PT has a strong preference to have insurance cover, and this preference does not change regardless of the profit factor q.

Table 9
Overall value (PT)/Expected utility (EUT) for risk curve π_1 when $q = 0$ and $q = 0.3$. The highest values (where applicable) are highlighted in **bold**.

Profit factor	Overall value (PT) Expected utility (EUT)		
$q = 0$	$i_r = 0$	$i_r = 0.8$	$i_r = 1$
PT, $\alpha = 0.80$	−23.96	−18.15	**−17.99**
PT, $\alpha = 0.88$	−31.73	−22.48	**−22.2**
PT, $\alpha = 0.95$	−40.71	−27.14	**−26.69**
EUT, $r = 0.88$	9986.19	9986.19	9986.19
EUT, $r = 1$	9986.19	9986.19	9986.19
$q = 0.3$			
PT, $\alpha = 0.80$	−23.96	−19.03	**−18.94**
PT, $\alpha = 0.88$	−31.73	−23.66	**−23.49**
PT, $\alpha = 0.95$	−40.71	−28.64	**−28.34**
EUT, $r = 0.88$	**9986.19**	9985.33	9985.33
EUT, $r = 1$	**9986.19**	9985.33	9985.33

On the other hand, the best option for decision-makers who behave according to EUT depends on whether the premiums are fair or not. For fair premiums, the cost of the insurance exactly equals the expected loss and therefore, as mathematically shown using Eqs. (14) and (15), the expected utility for all three insurance options will be exactly the same. Consequently, the optimal resource allocation to C_{cs} under EUT remains unchanged. This suggests that when premiums are fair, the decision-makers behaving in line with EUT are agnostic to the level of insurance cover chosen including the case of no insurance.

For premiums that include profit margin, under the EUT optimal solution, decision makers allocate a higher amount to C_{cs} in order to reduce risk. They maximize expected utility by not investing in insurance, probably because of the added costs due to expensive insurance premiums. However, the difference in the expected utilities is extremely small. Thus, we could say that when premiums are not fair, decision-makers considering EUT slightly prefer a no-insurance option to the one with insurance.

The above trends are true regardless of the risk curve and therefore, to avoid repetition, Table 9 shows the overall value and the expected utility only for risk curve π_1 under both cases of fair and unfair premiums.

5.5. Sensitivity analysis

Since the scale of operations will be different for different organizations, so will be their wealth, losses and cybersecurity control expenditures. From the optimal resource allocation point of view, the relative proportions of these quantities is important, not the absolute values. In our examples, we have assumed that the losses are 4% of the wealth and the cybersecurity control expenses are only a fraction of the overall wealth, as reported by current research (Kamiya et al., 2021; Walton et al., 2021). We performed sensitivity analysis to understand the robustness of our numerical results and found that the key findings are robust to varying values of W, but also to different relative proportions of L with respect to W.

6. Conclusion and further work

6.1. Key findings

We compare and contrast the optimal allocation of resources to cybersecurity controls and cyber insurance based on PT and EUT. Not only do we propose the first PT based optimal resource allocation model for cyber insurance and cybersecurity controls, but we also advance the existing work on EUT based optimal resource allocation model since ours is the first model to consider actuarially derived premiums and a

functional model for risk curves and also find a jointly optimal solution for both cyber security investment as well as cyber insurance premiums. Using conjectures, mathematical results and numerical results, we illuminate why decision-makers that behave in line with PT could allocate resources to the two alternatives differently than if they behaved in line with EUT. We also introduce a new model for risk curves and show that the shape of the risk curves critically influences the optimal resource allocation.

We find that the following three factors influence the optimal resource allocation to cybersecurity controls and cyber insurance.

1. *Challenging cybersecurity environment*. The risk curve models how challenging the security environment is. Higher baseline probability and slower or slowing decay in the risk curve indicate a challenging security environment with an elevated and/or persistent level of risk. Under both EUT and PT paradigms, decision-makers tend to make higher cybersecurity investments in such an environment.
2. *Behavioral factors*. Some behavioral factors significantly influence the risk allocation, others do not. Specifically, we find the following:
   - *PT*. Diminishing sensitivity and probability weighing affect the optimal resource allocation in two different ways. Less diminishing sensitivity or the presence of probability weighing lead to a higher investment in cybersecurity controls. In contrast, higher diminishing sensitivity or the absence of probability weights lead to lower levels of investment. Surprisingly, loss aversion has no effect on the optimal allocation of resources. The choice of the reference point is also vital as all of the optimality calculations depend on that choice.
   - *EUT*. The risk aversion parameter in a CRRA type utility function has negligible effect on the resource allocation. Contrary to the prevailing hypothesis that a rational, risk-averse decision-maker would, under fair premiums, buy full insurance (Schmidt, 2016; Marotta et al., 2017), we show that in the case of fair premiums, Expected Utility Theory (EUT) is agnostic to buying cyber insurance or not.
3. *Specifics of insurance cover*. Decision-makers behaving in line with PT invest more in cybersecurity controls as the level of insurance decreases and prefer an option with insurance to no insurance. On the contrary, decision-makers behaving in line with EUT are agnostic about the level of insurance cover when the premiums are fair and only slightly prefer a no-insurance option when they are not. Though, when the premiums include a profit margin, the insurance premiums are expensive. As a result, both EUT and PT point to a higher investment in cybersecurity controls.

6.2. Limitations

Our results are only limited to EUT using a standard CRRA utility function. Risk aversion can be modeled in a utility function using many other ways (Back, 2017) and other behavioral characteristics such as regret can also be considered in a utility function (Ejaz et al., 2022). It is beyond the scope of this manuscript to perform an exhaustive comparison that considers all possible variations of EUT and PT.

Estimation of loss L could be challenging. When deriving and comparing the optimal resource allocation to two alternative cybersecurity investments, we assume that the Loss can be estimated. While its estimation is crucial, we do not discuss how to do it here since that is outside the scope of this work.

6.3. Contributions and further work

Our study is the first to consider the optimal resource allocation to cybersecurity controls and cyber insurance by comparing PT and EUT. In doing so, we derive novel insights into the optimal allocations under both EUT and PT that have not been highlighted until now. Contrary to the prior belief that EUT using a risk averse utility function will lead the decision-maker to buying an insurance, we mathematically show that they are actually indifferent about buying a cyber insurance, and, in fact, slightly prefer the no insurance option when the premiums are expensive because of the insurance company's profit margin. Our conjectures and numerical examples show that it is the probability weight parameter (and not the loss aversion parameter) in the PT value function that leads to a loss averse resource allocation — higher investment in cyber security compared to EUT — in case of partial or no insurance. But we also mathematically prove that in the case of full insurance, PT will allocate less to cyber security controls compared to EUT. Finally, we propose a multiplicative linear regression function to model the risk curve. Such a model is very easy to interpret and a unique risk curve could be easily fitted for a given organization.

However, collecting the data required to fit the risk curve is challenging because accurate and up-to-date estimates of cyber incident probabilities given a certain investment are unlikely to be available. This is because new cyber threats emerge every second and many instances of a successful cyber-attack are never reported in a public database. Even within a single organization that would have all the internal information available, it is difficult to determine how much a specific investment in controls will reduce the probability of a cyber-attack, because the organization may never become a target. Therefore, in practice, as highlighted by Paté-Cornell et al. (2018), risk curves will require quantifying managerial or cyber expert's perception (judgment) to supplement available data. In fact, this is the basis on which cybersecurity investment decisions are often made. Undoubtedly, more research is needed to quantify risk curves empirically. Future studies could then validate our theoretical developments in real-world scenarios.

CRediT authorship contribution statement

Chaitanya Joshi: Writing – review & editing, Writing – original draft, Supervision, Methodology, Investigation, Formal analysis, Conceptualization. **Sergeja Slapničar:** Writing – review & editing, Writing – original draft, Methodology, Investigation. **Jinming Yang:** Writing – original draft, Methodology, Investigation, Formal analysis. **Ryan K.L. Ko:** Writing – review & editing, Investigation.

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Acknowledgment

The authors would like to thank the two anonymous referees for their constructive comments, which helped in significantly improving the paper, and to H.R. Skeotch for pointing us to some of the previous literature. Jinming Yang's work was made possible due to the internal research funding provided by The University of Auckland.

Data availability

No data was used for the research described in the article.

References

Adler, S., 2024. Merck reaches settlement with insurers over $1.4 billion NotPetya malware attack. Hipaa J..

Arce, D., Woods, D.W., Böhme, R., 2024. Economics of incident response panels in cyber insurance. Comput. Secur. 140, 103742.

Back, K.E., 2017. Utility and risk aversion. In: Asset Pricing and Portfolio Choice Theory. Oxford University Press.

Banks, D.L., Rios, J., Ríos Insua, D., 2015. Adversarial Risk Analysis. CRC Press, Boca Raton, FL.

Barberis, N.C., 2013. Thirty years of prospect theory in economics: A review and assessment. J. Econ. Perspect. 27 (1).

Barseghyan, L., Molinari, F., O'Donoghue, T., Teitelbaum, J.C., 2013. The nature of risk preferences: Evidence from insurance choices. Am. Econ. Rev. 103 (6), 2499–2529.

Bell, D., 1985. Disappointment in decision-making. Oper. Res. 33 (1), 1–27.

Biener, C., Eling, M., Wirfs, J.H., 2015. Insurability of cyber risk: An empirical analysis. Geneva Pap. Risk Insur. Issues Pr. 40 (1), 131–158.

Boehm, J., Curcio, N., Merrath, P., Shenton, L., Stahle, T., 2019. The risk-based approach to cybersecurity. McKinsey & Company.

Böhm, R., Laube, S., Riek, M., 2018. A fundamental approach to cyber risk analysis. Variance 12 (2).

Bruhin, A., Fehr-Duda, H., Epper, T., 2010. Risk and rationality: Uncovering heterogeneity in probability distortion. Econometrica 78 (4), 1375–1412.

Chase, J., Niyato, D., Wang, P., Chaisiri, S., Ko, R.K.L., 2019. A scalable approach to joint cyber insurance and security-as-a-service provisioning in cloud computing. IEEE Trans. Dependable Secur. Comput. 16 (4), 565–579.

Cho, H., Lee, J.-S., Chung, S., 2010. Optimistic bias about online privacy risks: Testing the moderating effects of perceived controllability and prior experience. Comput. Hum. Behav. 26 (5), 987–995.

Cremer, F., Sheehan, B., Fortmann, M., Mullins, M., Murphy, F., Materne, S., 2024a. Bridging the cyber protection gap: An investigation into the efficacy of the German cyber insurance market. Risk Manag. Insur. Rev. 27 (1), 57–87.

Cremer, F., Sheehan, B., Mullins, M., Fortmann, M., Ryan, B.J., Materne, S., 2024b. On the insurability of cyber warfare: An investigation into the German cyber insurance market. Comput. Secur. 142, 103886.

de Smidt, G., Botzen, W., 2018. Perceptions of corporate cyber risks and insurance decision-making. Geneva Pap. Risk Insur. Issues Pr. 43 (2), pp. 239–274.

Ejaz, M., Joe, S., Joshi, C., 2021a. Adversarial risk analysis for auctions using mirror equilibrium and Bayes Nash equilibrium. Decis. Anal. 18 (3), 185–202.

Ejaz, M., Joshi, C., Joe, S., 2021b. Adversarial risk analysis for first-price sealed-bid auctions. Aust. N. Z. J. Stat. 63 (2), 357–376.

Ejaz, M., Joshi, C., Joe, S., 2022. Adversarial risk analysis for auctions using non-strategic play and level-k thinking: A general case of n bidders with regret. Comm. Statist. Theory Methods 1–19. http://dx.doi.org/10.1080/03610926.2022.2042023.

Eling, M., Schnell, W., 2016. What do we know about cyber risk and cyber risk insurance? J. Risk Financ. 17 (5).

Eling, M., Wirfs, J., 2019. What are the actual costs of cyber risk events? European J. Oper. Res. 272 (3), 1109–1119.

Etner, J., Jeleva, M., Tallon, J.-M., 2012. Decision theory under ambiguity. J. Econ. Surv. 26 (2), 234–270.

Fama, E.F., 1980. Agency problems and the theory of the firm. J. Political Econ. 88 (8), 288–307.

Ferland, J., 2019. Cyber insurance — What coverage in case of an alleged act of war? Questions raised by the mondelez v. Zurich case. Comput. Law Secur. Rev. 35 (4), 369–376.

Freund, J., Jones, J., 2014. Measuring and Managing Information Risk: A FAIR Approach, first ed. Elsevier Science and Technology, Oxford, England.

Gale, M., Bongiovanni, I., Slapničar, S., 2022. Governing cybersecurity from the boardroom: Challenges, drivers, and ways ahead. Comput. Secur. 121.

Gendron, Y., Samsonova-Taddei, A., Guénin, H., 2020. Making sense of risk management as a (dis)comfort-inducing practice. Behav. Res. Account. 33.

Gilboa, I., Marinacci, M., 2013. Ambiguity and the Bayesian paradigm. In: Acemoglu, D., Arellano, M., Dekel, E. (Eds.), Advances in Economics and Econometrics: Tenth World Congress. Cambridge University Press, pp. 179–242.

Gonzalez, R., Wu, G., 1999. On the shape of the probability weighting function. Cogn. Psychol. 38 (1), 129–166.

Gordon, L.A., Loeb, M.P., 2002. The economics of information security investment. ACM Trans. Inf. Syst. Secur. 5 (4).

Gordon, L.A., Loeb, M.P., Lucyshyn2, W., Zhou, L., 2015. The economics of information security investment. J. Inf. Secur. 6 (6).

Gordon, L.A., Loeb, M.P., Sohail, T., 2003. A framework for using insurance for cyber-risk management. 46, (3).

Hubbard, D.W., Seiersen, R., 2023. How to Measure Anything in Cybersecurity Risk, second ed. Wiley.

Huseyin Cavusoglu, S.R., Yue, W.T., 2008. Decision-theoretic and game-theoretic approaches to IT security investment. J. Manage. Inf. Syst. 5 (2), 281–304.

Hwang, I.D., 2021. Prospect theory and insurance demand: Empirical evidence on the role of loss aversion. J. Behav. Exp. Econ. 95, 101764.

Jalali, M.S., Siegel, M., Madnick, S., 2019. Decision-making and biases in cybersecurity capability development: Evidence from a simulation game experiment. J. Strat. Inf. Syst. 28 (1), 66–82.

Julisch, K., 2013. Understanding and overcoming cyber security anti-patterns. Comput. Netw. 57 (10), 2206–2211.

Kahneman, D., Lovallo, D., 1993. Timid choices and bold forecasts: A cognitive perspective on risk taking. Manag. Sci. 39 (1), 17–31.

Kahneman, D., Tversky, A., 1979. Prospect theory: An analysis of decision under risk. Econometrica 47 (2), 363–391.

Kamiya, S., Kang, J.-K., Kim, J., Milidonis, A., Stulz, R.M., 2021. Risk management, firm reputation, and the impact of successful cyberattacks on target firms. J. Financ. Econ. 139 (3), 719–749.

Kay, J., King, M., 2020. Radical Uncertainty, Decision-Making Beyond the Number. W.W.Norton, New York.

Komljenovic, D., Gaha, M., Abdul-Nour, G., Langheit, C., Bourgeois, M., 2016. Risks of extreme and rare events in asset management. Saf. Sci. 88, 129–145.

Kunreuther, H., Pauly, M., 2004. Neglecting disaster: Why don't people insure against large losses? J. Risk Uncertain. 28, 5–21.

Lyytinen, K., Mathiassen, L., Ropponen, J., 1998. Attention shaping and software risk—A categorical analysis of four classical risk management approaches. 9, (3), pp. 233–255.

March, J.G., Shapira, Z., 1987. Managerial perspectives on risk and risk taking. Manag. Sci. 33 (11), 1404–1418.

Marotta, A., Martinelli, F., Nanni, S., Orlando, A., Yautsiukhin, A., 2017. Cyber-insurance survey. Comput. Sci. Rev. 24, 35–61.

Mazzoccoli, A., Naldi, M., 2020. Robustness of optimal investment decisions in mixed insurance/investment cyber risk management. Risk Anal. 40 (3), 550–564.

Miller, L., 2019. Cyber insurance: An incentive alignment solution to corporate cyber-insecurity. J. Law Cyber Warf. 7 (2), 147–182.

Mott, G., Turner, S., Nurse, J.R.C., MacColl, J., Sullivan, J., Cartwright, A., Cartwright, E., 2023. Between a rock and a hard(ening) place: Cyber insurance in the ransomware era. Comput. Secur. 128, 103162.

Mukhopadhyay, A., Chatterjee, S., Saha, D., Mahanti, A., Sadhukhan, S.K., 2013. Cyber-risk decision models: To insure IT or not? Decis. Support Syst. 56, 11–26.

Oblak, K., Ličen, M., Slapničar, S., 2018. The role of cognitive frames in combined decisions about risk and effort. Manag. Account. Res. 39, 35–46.

Öğüt, H., Raghunathan, S., Menon, N., 2011. Cyber security risk management: Public policy implications of correlated risk, imperfect ability to prove loss, and observability of self-protection. Risk Anal. 31 (3), 497–512.

Oltramari, A., Kott, A., 2018. Towards a reconceptualisation of cyber risk: An empirical and ontological study. J. Inf. Warf. 17 (1), 49–73.

Paté-Cornell, M.-E., Kuypers, M., Smith, M., Keller, P., 2018. Cyber risk management for critical infrastructure: A risk analysis model and three case studies. Risk Anal. 38 (2), 226–241.

Pfleeger, S.L., Caputo, D.D., 2012. Leveraging behavioral science to mitigate cyber security risk. Comput. Secur. 31 (4), 597–611.

Pitthan, F., De Witte, K., 2021. Puzzles of insurance demand and its biases: A survey on the role of behavioural biases and financial literacy on insurance demand. J. Behav. Exp. Financ. 30, 100471.

Pollmeier, S., Bongiovanni, I., Slapničar, S., 2023. Designing a financial quantification model for cyber risk: A case study in a bank. Saf. Sci. 159, 106022.

Power, M., 2009. The risk management of nothing. Account. Organ. Soc. 34 (6), 849–855.

Rao, N.S.V., Poole, S.W., Ma, C.Y.T., He, F., Zhuang, J., Yau, D.K.Y., 2016. Defense of cyber infrastructures against cyber-physical attacks using game-theoretic models. Risk Anal. 36 (4), 694–710.

Rhee, H.-S., Ryu, Y.U., Kim, C.-T., 2012. Unrealistic optimism on information security management. Comput. Secur. 31 (2), 221–232.

Rios Insua, D., Couce-Vieira, A., Rubio, J.A., Pieters, W., Labunets, K., G. Rasines, D., 2021. An adversarial risk analysis framework for cybersecurity. Risk Anal. 41 (1), 16–36.

Romanosky, S., 2016. Examining the costs and causes of cyber incidents. J. Cybersecur. 2 (2), 121–135.

Schmidt, U., 2016. Insurance demand under prospect theory: A graphical analysis. J. Risk Insur. 83 (1), 77–89.

Schmidt, U., Starmer, C., Sugden, R., 2008. Third-generation prospect theory. J. Risk Uncertain. 36, 203–223.

Shetty, S., McShane, M., Zhang, L., Kesan, J.P., Kamhoua, C.A., Kwiat, K., Njilla, L.L., 2018. Reducing informational disadvantages to improve cyber risk management.. Geneva Pap. Risk Insur. Issues Pr. 43, 224–238.

Skeoch, H.R.K., 2022. Expanding the Gordon-loeb model to cyber-insurance. Comput. Secur. 112, 102533.

Slapničar, S., Axelsen, M., Bongiovanni, I., Stockdale, D., 2023a. A pathway model to five lines of accountability in cybersecurity governance. Int. J. Account. Inf. Syst. 51, 100642.

Slapničar, S., Axelsen, M., Eulerich, M., 2023b. Measuring and managing cyber risk. Eur. Account. Assoc. Congr..

Sullivan, J., Nurse, J.R., 2021. Cyber security incentives and the role of cyber insurance. In: RUSI Emerging Insights Paper. Royal United Services Institute (RUSI), University of Kent.

Sydnor, J., 2010. (Over)insuring modest risks. Am. Econ. J.: Appl. Econ. 2 (4), 177–199.
Taleb, N.N., 2007. The Black Swan: The Impact of the Highly Improbable. Random House Trade.
Tversky, A., Kahneman, D., 1992. Advances in prospect theory: Cumulative representation of uncertainty. J. Risk Uncertain. 5, 297–323.
Uuganbayar, G., Yautsiukhin, A., Martinelli, F., Massacci, F., 2021. Optimisation of cyber insurance coverage with selection of cost effective security controls. Comput. Secur. 101, 102121.
Von Neumann, J., Morgenstern, O., 1947. The Theory of Games and Economic Behavior, second ed. Princeton University Press., Princeton.
Walton, S., Wheeler, P.R., Zhang, Y.I., Zhao, X.R., 2021. An integrative review and analysis of cybersecurity research: Current state and future directions. J. Inf. Syst. 35 (1), 155–186.
WEF, 2024. The Global Risks Report 2024, Insights Report, ninteenth ed. World Economic Forum.
Woods, D.W., Weinkle, J., 2020. Insurance definitions of cyber war. Geneva Pap. Risk Insur. - Issues Pr. 45, 639–656.
Wrede, D., Stegen, T., Graf von der Schulenburg, J.M., 2020. Affirmative and silent cyber coverage in traditional insurance policies: Qualitative content analysis of selected insurance products from the German insurance market. Geneva Pap. Risk Insur. - Issues Pr. 45, 657–689.
Young, D., Lopez, J., Rice, M., Ramsey, B., McTasney, R., 2016. A framework for incorporating insurance in critical infrastructure cyber risk strategies. Int. J. Crit. Infrastruct. Prot. 14, 43–57.
Yurcik, W., Doss, D., 2002. Cyberinsurance: A market solution to the internet security market failure. In: Proceedings of WEIS.